Sicurezza dei Sistemi Informativi

Appello d'Esame del 16 Giugno 2022

Anno Accademico 2021-2022

Politecnico di Torino — Docente: Prof. Cataldo Basile

2022-06-16

1 Testo Ufficiale dell'Esame

Domanda 1: Domande a Risposta Multipla

Rispondere ai seguenti quesiti a risposta multipla specificando l'opzione corretta e giustificando analiticamente la risposta:

1.1 Cosa è AES-192?

a. Un algoritmo di crittografia asimmetrica

b. Un algoritmo di hash con digest a 192 bit

c. Un algoritmo di crittografia simmetrica a blocchi con chiave e blocco da 192 bit

d. Un algoritmo di crittografia simmetrica di tipo stream con chiave e nonce da 192 bit

e. Nessuna delle precedenti

1.2 Cosa è un Trusted Platform Module (TPM)?

a. Un modulo software per il controllo delle licenze

b. Un chip crittografico hardware sicuro saldato sulla scheda madre per la memorizzazione protetta di chiavi e misurazione dell'integrità di boot

c. Un protocollo di rete per l'autenticazione Wi-Fi

d. Un firewall applicativo integrato nel sistema operativo

Domanda 2: Metodologie per la Stima dei Rischi

Spiegare quali sono i principali approcci metodologici per la stima dei rischi di sicurezza informatica. In particolare:

- Spiegare come dai dati di *Risk Assessment* e di *Risk Framing* si ottengono le stime qualitative e quantitative del rischio;
- Descrivere le formule di calcolo del rischio quantitativo: Annualized Rate of Occurrence (ARO), Single Loss Expectancy (SLE) e Annualized Loss Expectancy (ALE);
- Discutere i punti di forza e i limiti di ciascun approccio (qualitativo vs quantitativo).

Domanda 3: Controllo degli Accessi (DAC vs MAC vs RBAC)

Confrontare dettagliatamente i tre principali modelli di controllo dell'accesso logico:

a. **Discretionary Access Control (DAC)**;

b. **Mandatory Access Control (MAC)**;

c. **Role-Based Access Control (RBAC)**.

Per ciascuno, descrivere su quali entità si basano le decisioni di autorizzazione, chi ha l'autorità di modificare i permessi e riportare esempi concreti di applicazione (es. permessi UNIX, etichette SELinux, ruoli aziendali).

Domanda 4: Autenticazione e Integrità in IPsec (AH vs ESP)

Descrivere i protocolli di sicurezza dello standard IPsec (Authentication Header - AH e Encapsulating Security Payload - ESP). Spiegare per ciascuno quali proprietà di sicurezza garantiscono (confidenzialità, integrità, autenticazione dell'origine, anti-replay) e come operano nelle due modalità *Transport Mode* e *Tunnel Mode*. Spiegare perché AH è incompatibile con il NAT (Network Address Translation).

2 Soluzione Dettagliata e Guida Risolutiva

Soluzione Domanda 1: Risposta Multipla

1.1 AES-192 (Analisi Puntuale delle Opzioni):

- **a. FALSA**: AES (Advanced Encryption Standard / Rijndael, FIPS PUB 197) è un algoritmo a chiave simmetrica (crittografia a chiave segreta condivisa), non un cifrario asimmetrico a chiave pubblica.
- **b. FALSA**: AES è un algoritmo di cifratura reversibile a blocchi, non una funzione crittografica di hash a senso unico (come SHA-192, che peraltro non è uno standard; la famiglia SHA-2 include SHA-224, SHA-256, SHA-384, SHA-512).
- **c. FALSA**: Sebbene la chiave sia da 192 bit, in AES la dimensione del blocco di cifratura è **fissa e invariabile a 128 bit** (16 byte) per tutte le varianti (AES-128, AES-192, AES-256). Solo il cifrario originario Rijndael supportava blocchi da 192 e 256 bit, ma nello standard federale AES il blocco è unicamente da 128 bit.
- **d. FALSA**: AES è nativamente un cifrario a blocchi (*block cipher*) operante tramite una rete SPN (Substitution-Permutation Network), non uno stream cipher (sebbene possa essere impiegato in modalità a flusso come CTR od OFB).
- **e. VERA**: Poiché tutte le affermazioni precedenti contengono errori tecnici su natura, dimensione del blocco o classificazione dell'algoritmo, l'opzione corretta è univocamente la **(e)**.

1.2 Trusted Platform Module - TPM (Analisi Puntuale delle Opzioni):

- **a. FALSA**: Il TPM non è una libreria software per licenze DRM, bensì un coprocessore crittografico fisico e dedicato (standardizzato ISO/IEC 11889 e TCG).
- **b. VERA**: Il TPM è un chip crittografico sicuro saldato sulla motherboard (o integrato in firmware fTPM) deputato a fungere da *Hardware Root of Trust*. Genera e custodisce chiavi crittografiche non estraibili (Endorsement Key EK, Storage Root Key SRK) e contiene registri Platform Configuration Registers (PCR) che registrano la catena di hash delle componenti software durante il *Measured Boot* (dall'UEFI fino al kernel OS).
- **c. FALSA**: L'autenticazione Wi-Fi è governata da protocolli di livello 2 come IEEE 802.11i, IEEE 802.1X, ed EAP (EAP-TLS, EAP-PEAP), che possono eventualmente usare certificati protetti da TPM ma non si identificano con esso.
- **d. FALSA**: Il TPM è un componente di sicurezza hardware e computazione crittografica sicura, non ha alcuna funzione di ispezione dei pacchetti di rete o firewall applicativo (L7).

Soluzione Domanda 2: Metodologie di Stima del Rischio

Inquadramento Generale: Il rischio informatico è funzione della probabilità che una minaccia (*Threat*) sfrutti con successo una vulnerabilità (*Vulnerability*) di un asset aziendale, causando un impatto negativo (*Impact*):

$$\text{Rischio} = f(\text{Minaccia}, \text{Vulnerabilità}, \text{Impatto})$$

Il **Risk Framing** stabilisce il contesto strategico: definisce la propensione al rischio dell'organizzazione (*Risk Appetite*), le priorità aziendali, i vincoli legali/normativi e le ipotesi operative. Il **Risk Assessment** raccoglie i dati sul campo identificando asset, minacce e vulnerabilità.
Approccio Quantitativo: Fornisce stime numeriche ed economiche basate su parametri finanziari:

- **Asset Value (AV)**: Valore economico complessivo dell'asset protetto (es. valore dell'hardware, dei dati e dei costi di fermo servizio).
- **Exposure Factor (EF)**: Percentuale di perdita del valore dell'asset causata dal verificarsi della minaccia ($0 \leq EF \leq 1$).
- **Single Loss Expectancy (SLE)**: Danno economico atteso per il verificarsi di un singolo incidente:
$$SLE = AV \times EF$$
- **Annualized Rate of Occurrence (ARO)**: Frequenza stimata con cui la minaccia si manifesta nell'arco di un anno solare (es. una volta ogni due anni $\rightarrow ARO = 0.5$; tre volte all'anno $\rightarrow ARO = 3$).
- **Annualized Loss Expectancy (ALE)**: Perdita finanziaria annua stimata:
$$ALE = SLE \times ARO = AV \times EF \times ARO$$

Analisi Costi-Benefici delle Contromisure: Se l'introduzione di un controllo di sicurezza riduce l'ALE da ALE_1 a ALE_2 e il costo annuo del controllo è ACS (Annualized Cost of Safeguard), il controllo è economicamente conveniente se:

$$\Delta ALE - ACS = (ALE_1 - ALE_2) - ACS > 0$$

Approccio Qualitativo: Utilizza matrici di rischio semiquantitative (es. Matrice 5×5) assegnando a Probabilità e Impatto classi discrete (Molto Basso, Basso, Medio, Alto, Critico). È ampiamente utilizzato quando i dati storici statistici per calcolare l'ARO non sono disponibili o per rischi intangibili (danno d'immagine, perdita di reputazione, impatto legale).

Soluzione Domanda 3: Confronto DAC vs MAC vs RBAC

Proprietà	DAC (Discretionary)	MAC (Mandatory)	RBAC (Role-Based)
Principio Base	Basato sull'identità del soggetto e sul possesso/proprietà dell'oggetto (*Owner*).	Basato su etichette di sicurezza (*Labels*) e regole imposte a livello di sistema operativo.	Basato sulle funzioni o compiti lavorativi assegnati ai soggetti (*Roles*).
Autorità sui Permessi	Il proprietario dell'oggetto ha la discrezione assoluta di concedere o revocare permessi ad altri soggetti.	Imposta esclusivamente dall'amministratore di sicurezza globale. L'owner non può alterare le policy.	L'amministratore assegna permessi ai ruoli e assegna utenti ai ruoli (*Role Assignment*).
Regole di Accesso	Matrice di Accesso, Access Control List (ACL) e permessi POSIX (rwx).	Modelli di sicurezza formali: Bell-LaPadula (No Read Up, No Write Down), Biba.	Regole basate su ruoli e gerarchie di ruoli, con supporto al principio del minimo privilegio.
Esempi Reali	File system standard Linux/Windows (chmod, chown, NTFS ACL).	SELinux, AppArmor, sistemi militari/governativi multi-level (MLS).	Sistemi Enterprise ERP (SAP), database relazionali (GRANT role TO user).

Soluzione Domanda 4: IPsec — AH vs ESP e Incompatibilità con il NAT

Authentication Header (AH):

- Fornisce: Autenticazione dell'origine dei dati, integrità senza connessione, protezione anti-replay (tramite Sequence Number).
- **Non fornisce alcuna confidenzialità** (il payload viaggia in chiaro).
- Il calcolo dell'ICV (Integrity Check Value) include l'intero payload e tutti i campi immutabili dell'header IP esterno (escludendo solo i campi mutabili come TTL, Type of Service, Header Checksum).

Encapsulating Security Payload (ESP):

- Fornisce: Confidenzialità (cifratura simmetrica), autenticazione dell'origine dei dati, integrità e servizio anti-replay.
- L'autenticazione copre solo l'header ESP, il payload cifrato e l'ESP trailer. Non copre l'header IP esterno.

Transport Mode vs Tunnel Mode:

- *Transport Mode*: Protegge solo il payload di livello superiore (es. segmento TCP/UDP); l'header IP originale rimane intatto. Utilizzato per comunicazioni end-to-end tra due host.
- *Tunnel Mode*: L'intero pacchetto IP originale viene incapsulato e protetto all'interno di un nuovo pacchetto IP completo con un nuovo header esterno. Utilizzato per comunicazioni Gateway-to-Gateway (VPN site-to-site) o Host-to-Gateway (remote access VPN).

Incompatibilità di AH con il NAT: Il dispositivo NAT altera per definizione l'indirizzo IP di sorgente (SNAT) o destinazione (DNAT) nell'header IP del pacchetto durante l'attraversamento del gateway. Poiché il protocollo AH calcola l'ICV includendo gli indirizzi IP dell'header, quando il destinatario ricalcola l'ICV sull'header modificato dal NAT, la verifica crittografica fallisce inesorabilmente e il pacchetto viene scartato. ESP risolve questo problema (specialmente incapsulato in UDP port 4500 con NAT-Traversal).

Alternative Implementation Note: Concorrenza Rust per l'Elaborazione IPsec

Nei moderni router e gateway crittografici IPsec (come quelli realizzati con Rust su framework DPDK o Tokio/io_uring):

- `std::sync::Arc<SecurityAssociation>`: Le Security Association (SA), che contengono le chiavi di sessione e i parametri di crittografia, sono allocate all'interno di `Arc` e indicizzate in tabelle hash concorrenti senza blocco per garantire lookup parallelo su milioni di pacchetti/sec.
- `std::sync::atomic::AtomicU64`: Il numero di sequenza anti-replay a 64 bit viene incrementato in modo atomico (`fetch_add(1, Ordering::SeqCst)`) garantendo l'assenza di sovrapposizioni o race condition tra worker thread paralleli senza dover acquisire un pesante mutex.